

SEGURIDAD

MEJORES PRÁCTICAS DE PREVENCIÓN

MALWARE

Descripción

Software malicioso diseñado para dañar o acceder a un sistema sin autorización (virus, gusanos, troyanos, spyware).

Prevención

- Usar antivirus actualizado
- No descargar archivos sospechosos
- Mantener SO y aplicaciones actualizadas
- Usar cuentas de usuario con privilegios limitados
- Hacer copias de seguridad periódicas



WEB-BASED ATTACKS

ATAQUES DE DENEGACIÓN DE SERVICIO (DOS/DDOS)

Saturar un sistema o red con tráfico para que deje de estar disponible.

PREVENCIÓN

- Usar servicios de mitigación DDoS.
- Configurar reglas de firewall y rate limiting.
- Tener redundancia y ancho de banda suficiente.



ATAQUES DE INFORMACIÓN Y CREDENCIALES: FUERZA BRUTA

Intentar repetidamente diferentes combinaciones de credenciales hasta encontrar la correcta.

PREVENCIÓN

- Implementar autenticación multi-factor (MFA).
- Políticas de contraseñas robustas y únicas.
- Bloquear IPs después de intentos fallidos.

ATAQUES DE CONFIGURACIÓN Y SERVIDOR

Explotan configuraciones débiles en servidores y servicios (Puertos abiertos, servicios innecesarios, credenciales por defecto)

PREVENCIÓN

- Deshabilitar servicios innecesarios
- Cambiar configuraciones por defecto
- Escaneos de vulnerabilidades regulares

WEB APPLICATION ATTACKS



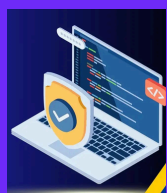
INYECCIÓN SQL (SQLI)

Inyectar código SQL malicioso en un campo de entrada para manipular la base de datos.



CROSS-SITE SCRIPTING (XSS)

Inyectar scripts maliciosos en páginas web vistas por otros usuarios.



FALSIFICACIÓN DE SOLICITUDES ENTRE SITIOS (CSRF)

Engañar a un usuario autenticado para que ejecute acciones no deseadas en una web.



INCLUSIÓN DE ARCHIVOS (FILE INCLUSION)

Forzar a una aplicación a incluir archivos remotos o locales, llevando a la ejecución de código.



CONFIGURACIÓN ERRÓNEA DEL SERVIDOR

Servidores con configuraciones de seguridad débiles (configuraciones por defecto, servicios innecesarios).



PREVENCIÓN

Usar consultas parametrizadas, principio de mínimo privilegio en la BD, escanear y sanitizar todas las entradas de usuario.

PREVENCIÓN

Sanitizar y validar toda la entrada del usuario, Implementar Content Security Policy y Codificar la salida de datos en HTML.

PREVENCIÓN

Usar tokens anti-CSRF en formularios, Validar el origen de las solicitudes (headers Referer/Origin) y Reautenticación para acciones críticas.

PREVENCIÓN

Deshabilitar allow_url_include, Validar y sanitizar las entradas que se usan para incluir archivos y Usar listas blancas de archivos permitidos.

PREVENCIÓN

Hardening del sistema (quitar servicios, cambiar puertos), Escaneos regulares de vulnerabilidades y Seguir guías de seguridad para cada servicio (OWASP).

PHISHING

Engañar a usuarios para que revelen información sensible mediante correos o mensajes falsos.

PREVENCIÓN

- Educación y concienciación del usuario.
- Filtros anti-spam y anti-phishing avanzados.
- Verificar la autenticidad de los enlaces y remitentes.



BIBLIOGRAFÍA

- <https://www.osha.gov/sites/default/files/publications/OSHA4170.pdf>
- https://cypfer.com/es/service/ransomware-recovery/?gad_source=1&gad_campaignid=21929957179&gbraid=0AAAAA96VFgA6fPBoXNseP5M5hY6i6am3O&clid=CjwKCAiA8vXIBhAtEiwAf3B-g82wkWXXFeEf8Yj7xEv-
- **Campos Elvira Valeria - 186831**
- **Ramos Quezada Katia - 187012**

SPAM

Descripción
Envío masivo y no solicitado de mensajes a un gran número de destinatarios a través de medios electrónicos.

Prevención
Usar filtros antispam, ser prudente con la dirección de correo electrónico y mantener los sistemas actualizados.



DISTRIBUTED DENIAL OF SERVICE (DDOS)

Descripción
Sobrecargar un servidor, servicio o red con un volumen masivo de tráfico ilegítimo para que no pueda atender a los usuarios reales.

Prevención

- Servicios de mitigación (ej. Cloudflare).
- Firewalls y redundancia.
- Monitorización de tráfico.

IDENTITY THEFT

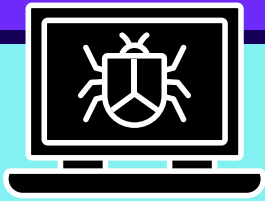
Descripción
El robo de identidad es un delito en el que una persona obtiene, transfiere o utiliza los datos personales de otra sin su autorización, usualmente para cometer un fraude o un acto ilegal.

Prevención
Para prevenir el robo de identidad, es fundamental adoptar una combinación de vigilancia constante, medidas de seguridad digital robustas y prácticas prudentes tanto en línea como fuera de línea.

DATA BREACH

Descripción
Es un incidente de seguridad en el que personas no autorizadas acceden y exponen información sensible o confidencial.

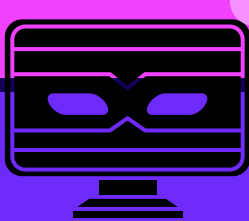
Prevención
Requiere un enfoque integral que combine medidas técnicas robustas, políticas organizacionales sólidas y concienciación de los empleados.



INSIDER THREAT

Descripción
Consiste en que una persona dentro de una organización, utiliza su acceso autorizado para causar daño a la red o los datos, ya sea de forma intencionada o no.

Prevención
Implementar políticas claras, capacitar continuamente a los empleados en seguridad, restringir el acceso a lo estrictamente necesario (privilegio mínimo), y usar herramientas de monitoreo como el análisis del comportamiento del usuario (UEBA) y la gestión de acceso privilegiado (PAM).



BOTNETS

Descripción
Redes de dispositivos infectados controlados por un atacante para realizar actividades maliciosas.

Prevención
Mantener software actualizado, usar antivirus y evitar descargar archivos sospechosos.

PHYSICAL MANIPULATION, DAMAGE, THEFT AND LOSS – CYN , CECY

Descripción
Acceso físico no autorizado a hardware que resulta en daño o robo.

Prevención
Control de acceso físico, medidas de seguridad en instalaciones y cifrado de dispositivos.

INFORMATION LEAKAGE

Descripción
Exposición no autorizada de datos confidenciales.

Prevención
Cifrado de datos, control estricto de accesos y políticas de manejo de información.

RANSOMWARE

Descripción
Malware que cifra archivos y exige un rescate para recuperarlos.

Prevención
Copias de seguridad frecuentes, no abrir enlaces sospechosos y parches de seguridad.

CYBER ESPIONAGE

Descripción
Robo de información confidencial por motivos políticos o económicos.

Prevención
Sistemas de detección de intrusos, segmentación de red y concienciación del usuario.

CRYPTOJACKING

Descripción
Uso no autorizado de recursos de un dispositivo para minar criptomonedas.

Prevención
Extensiones de navegador bloqueadoras, monitorización de rendimiento y software actualizado.

